2018

Global Azure

BOOTCAMP

VERONA

Gli sponsor Mondiali

Gli sponsor del nostro evento

2018 Global Azure BOOTCAMP

CloudGen

24/CO

Platinum Sponsor

Gli sponsor del nostro evento

2018 Global Azure BOOTCAMP

CloudGen

Insight®

Gold Sponsor

Gli sponsor del nostro evento

2018 Global Azure BOOTCAMP

CloudGen

digital joy

dgroove
Tecnologia emozionale.

Basic Sponsor

Tweet della giornata

2018 Global Azure BOOTCAMP

CloudGen

#GlobalAzure

@cloudgen_verona

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Chi sono

- Gianluca Hotz | @glhotz | ghotz@ugiss.org
- Fondatore e Mentor SolidQ
  - 20+ anni con SQL Server (dalla 4.21 nel 1996)
  - Modellazione basi di dati, dimensionamento e amministrazione, sviluppo, ottimizzazione
- Interessi
  - Modello relazionale, architettura DBMS, alta disponibilità e Disaster Recovery
- Community
  - 20 anni Microsoft MVP SQL Server (dal 1998)
  - Fondatore e presidente UGISS
    - User Group Italiano SQL Server (PASS Chapter)

Agenda

ARGOMENTO
SQL Server & GDPR
Introduzione

ARGOMENTO
SQL Server & GDPR
Scoperta e controllo accessi

ARGOMENTO
SQL Server & GDPR
Protezione

ARGOMENTO
SQL Server & GDPR
Always Encrypted

ARGOMENTO
SQL Server & GDPR
Row Level Security

ARGOMENTO
SQL Server & GDPR
Dynamic Data Masking

ARGOMENTO
SQL Server & GDPR
Continuità del servizio

ARGOMENTO
SQL Server & GDPR
Report e revisione

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

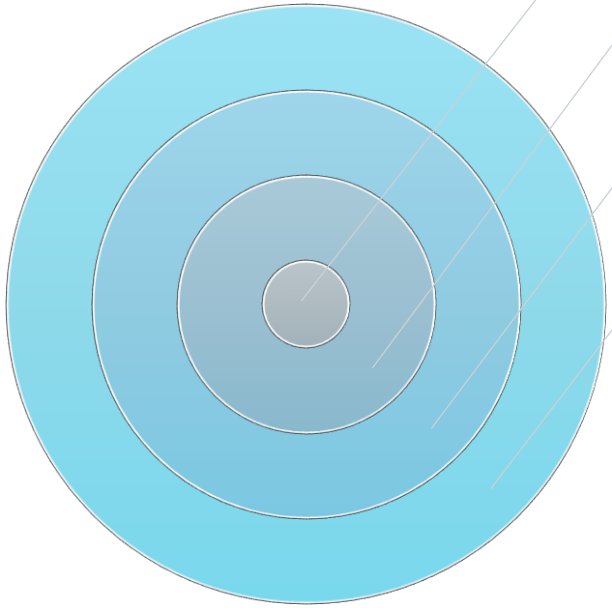
SQL Server & GDPR

Introduzione

GDPR: General Data Protection Regulation

- Normativa Europea (no direttiva!)
- Chiunque tratti dati di residenti EU
- Sanzioni 4% del fatturato o 20mio
- 25 Maggio 2018 (dopodomani!)
- Codici di condotta per Micro/PMI
- Approccio strutturato

Security Layering



Data Encryption

- Transport Layer Security (in transit)
- Transparent Data Encryption (at rest)
- Cell-Level Encryption (at rest)
- Always Encrypted (at rest and in transit)

Data Access

- Dynamic Data Masking
- Row-Level Security

Access Control

- Encrypted Authentication
- SQL Firewall*

Proactive monitoring

- Auditing
- Threat Detection*

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Scoperta e controllo accessi

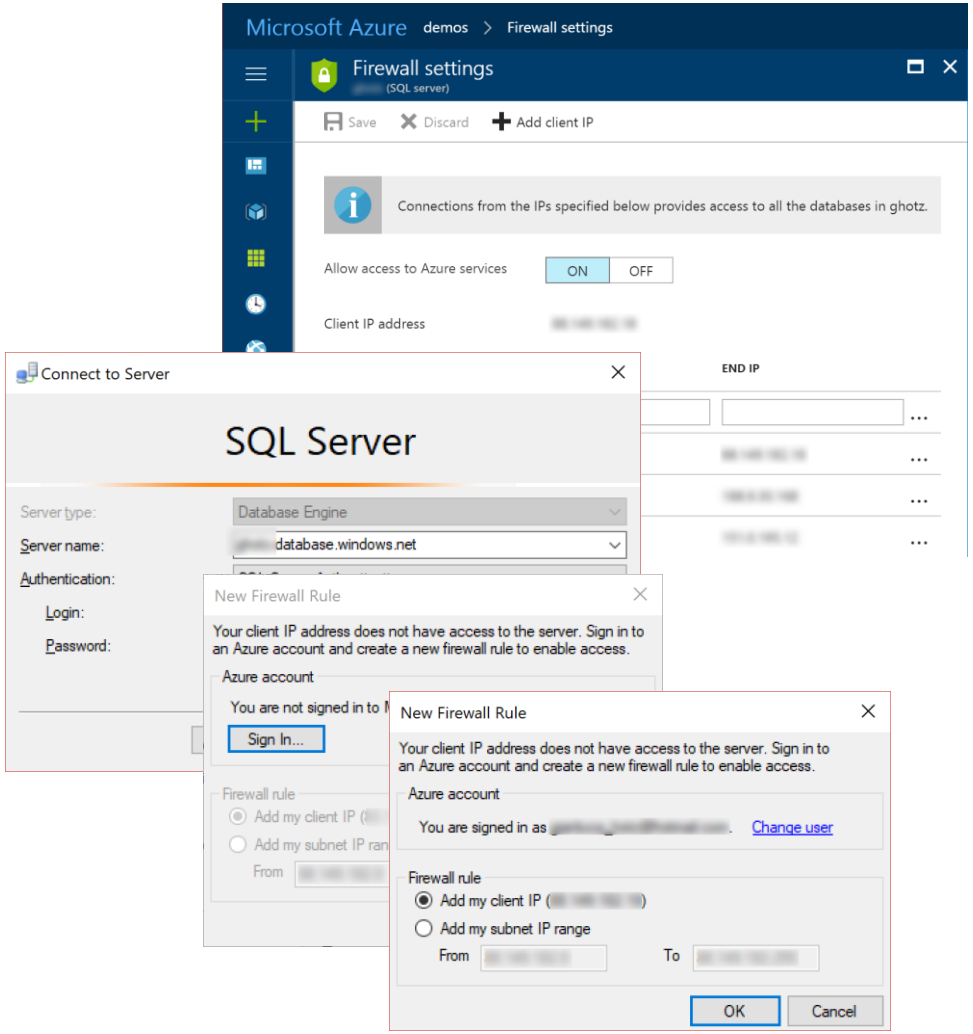
Controllo degli accessi

- Azure Database Firewall (che device)
- Autenticazione (chi sono)
- Autorizzazioni (cosa posso fare)

- Principio guida: minor privilegio!

Azure Database Firewall

- Accesso per servizi Azure
- Indirizzi IP Specifici
- Range di indirizzi IP
  - No 0.0.0.0-255.255.255.255 ☺
- Interfaccia SSMS
- Comandi T-SQL
- PowerShell, REST API



Autenticazione

- Due livelli: Server login e Database User
- Nativa SQL Server
- Integrata con Active Directory
  - Utilizza protocollo Kerberos
  - Supporto Azure Active Directory
  - Supporto Active Directory Universal Authentication
    - Multi-factor Authentication (es. via telefono)
    - Supportata solo con SSMS a partire dalla versione 17
- Best Practice
  - Autenticazione integrata
  - Database Containment (autenticazione a livello database)

Autorizzazioni

- Permessi granulari
  - **GRANT** cosa può fare **ON** su che oggetto **TO** chi
  - Ereditarietà gerarchia di oggetti
  - Assegnazione (**GRANT**), negazione (**DENY**), revocare (**REVOKE**)
  - Row Level Security
- Ruoli a livello di server e database
  - Es. sysadmin, dbcreator, db_datareader, db_datawriter
  - Specifici per alcune funzionalità (database msdb)
- Principio guida: <u>minor privilegio</u>!
  - Possibile elevare temporaneamente
    - Impersonation
    - Stored Procedure (in generale moduli T-SQL firmati)

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Protezione

Crittografia comunicazioni

- On-premise
  - Installazione Certificato (server e client)
  - Possibile forzare utilizzo (server e client)
  - Autenticazione sempre crittografata (nel caso «self-signed»)
- Azure SQL Database (e SQL Data Warehouse)
  - Connessione crittografata sempre necessaria!
  - Es. connessione ADO.NET Encrypt=True;TrustServerCertificate=False
- Transport Layer Security (TLS) 1.2
  - Windows Server 2008 R2
  - SQL Server 2008 SP4 (hotfix)

CloudGen
omnidi verso l'evoluzione

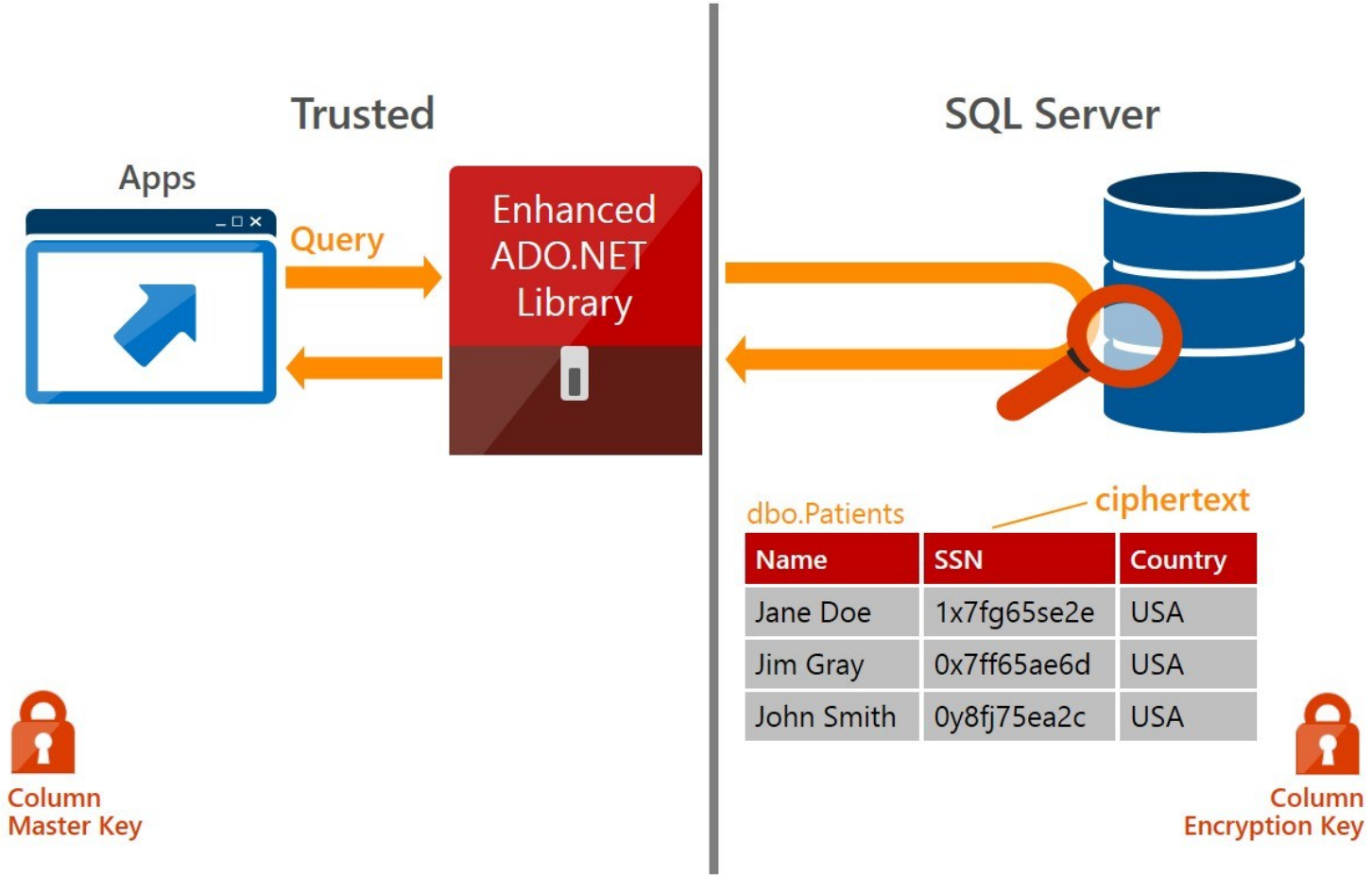
2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Always Encrypted

Panoramica Always Encrypted



DEMO

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Row Level Security

Panoramica Row Level Security

- Restringe l'accesso a un sottoinsieme di righe
- Basata su predicati di sicurezza
  - Definiti come «inline Table-Valued Functions»
  - «Filter predicate» limita righe a operazioni in lettura
    - SELECT, UPDATE e DELETE
  - «Block predicate» bloccano operazioni di scrittura
    - AFTER INSERT, AFTER/BEFORE UPDATE, BEFORE DELETE
- «Security Policy»
  - Applica i predicati di sicurezza alle tabelle

DEMO

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

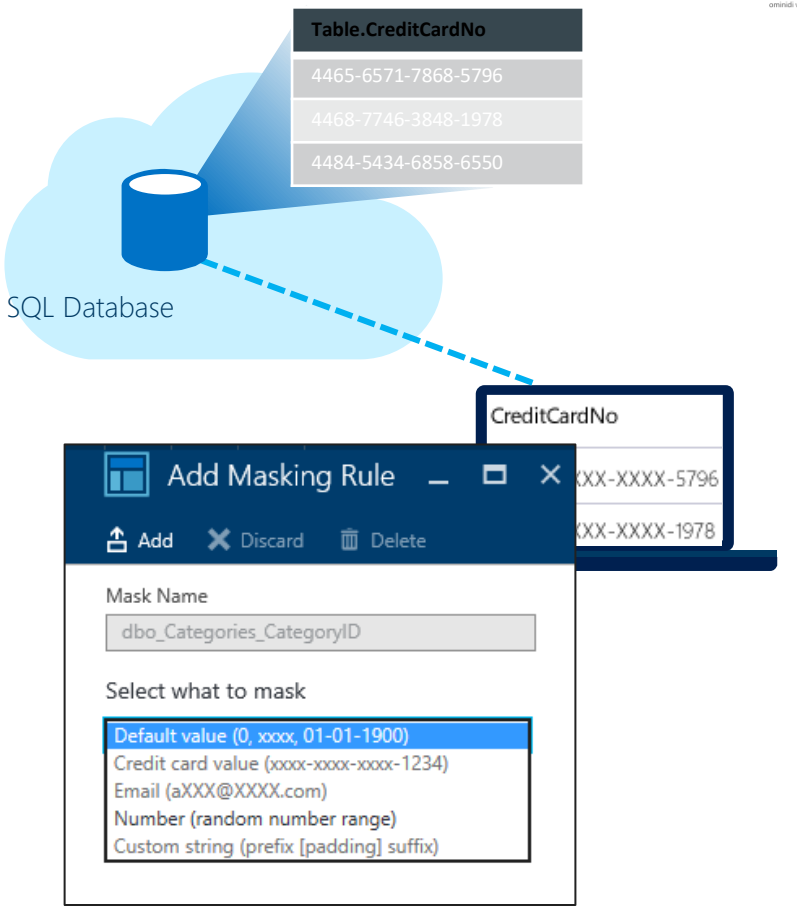
ARGOMENTO

SQL Server & GDPR

Dynamic Data Masking

Dynamic Data Masking

- Mascheramento
  - Real-time
  - Diversi tipi di maschere
  - Mascheratura parziale
- Basato su regole/permessi
  - A livello di colonna
  - Permesso di «unmask»
- Configurazione Azure nel portale



DEMO

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

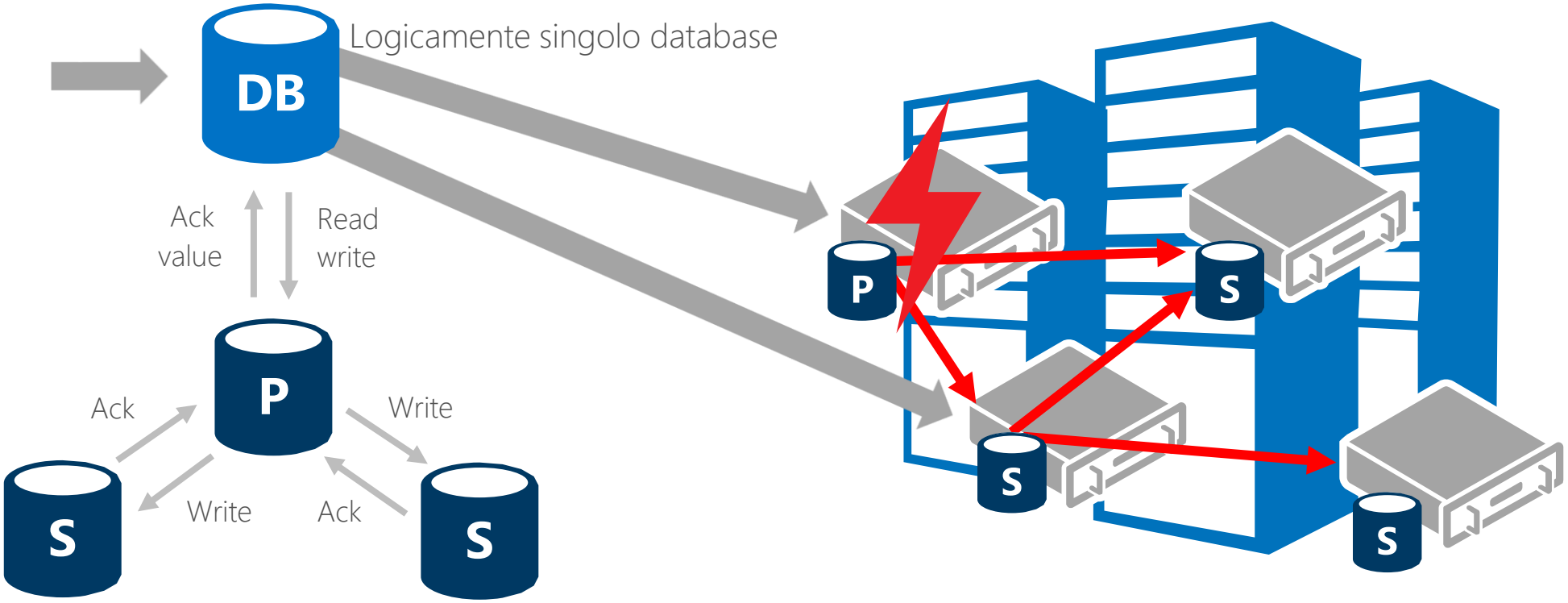
Continuità del servizio

AlwaysOn

- AlwaysOn Failover Cluster Instances
  - Basata su Shared Storage
  - DR con Storage Replication
- AlwaysOn Availability Groups
  - Replica dati

Azure SQL Database

- Possibilità di avere repliche geografiche
  - Standard 1 copia non accessibile, Active fino a 4 copie in sola lettura



Backup e restore

- Diversi modelli componibili
  - Completo (FULL), differenziale (DIFF), incrementale (LOG)
- «Point-in-time»
  - granularità fino a un punto in base a «retention»
  - Richiede modello di recovery FULL e backup log
- Possono essere crittografati
  - Attenzione a non perdere le chiavi crittografiche!
  - Automaticamente con TDE (default usa Database Key)

Backup & Restore in Azure SQL Database

- Automatici
  - «Full» settimanale
  - «Differenziale» qualche ora
  - «Log» ogni 5-10 minuti
- «Backup set»
  - Ridondati localmente
  - Ridondati geograficamente (regione geo-politica affine)
  - Long Term Backup Retention (in anteprima)
    - Settimanali mantenuti per 10 anni

CloudGen
omnidi verso l'evoluzione

2018
Global Azure
BOOTCAMP

ARGOMENTO

SQL Server & GDPR

Report e revisione

Cosa tracciare

- Accessi
  - SQL Server Trace (Profiler, deprecato)
  - SQL Server Audit
- Dati modificati (versioni precedenti)
  - Change Data Capture
  - Temporal Databases

SQL Server Audit

- Definizione gruppi di azioni da tracciare
  - Server
  - Database
- Target
  - File
  - Windows Log
- Disponibile con tutte le edizioni
  - a partire da SQL Server 2016 Service Pack 1
  - Implementazione diversa per Azure SQL Database

Azure SQL Database Threat Detection

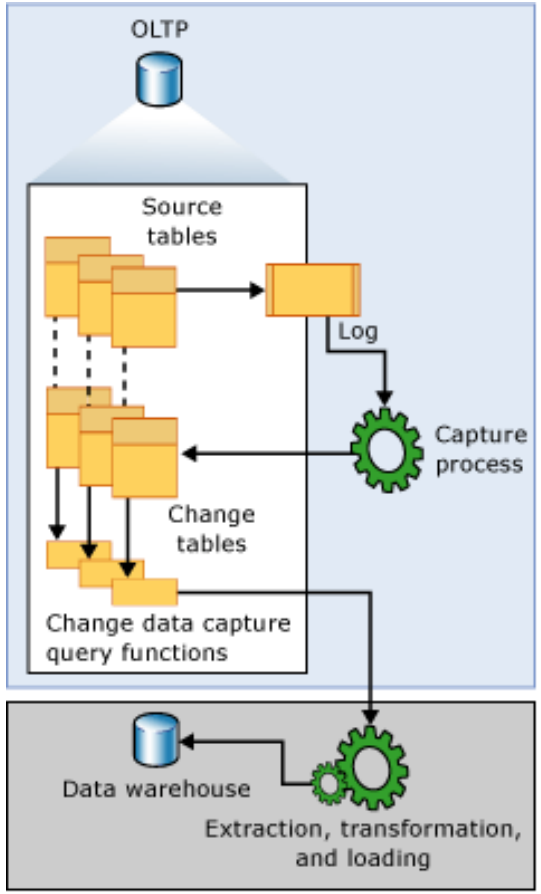
- Semplice opzione da attivare per database
  - Richiede attivazione «SQL Database Auditing»
- Rileva potenziali minacce/vulnerabilità
  - Attacchi di tipo «SQL Injection»
  - Accessi anomali (es. da luoghi anomali)
- Allarmi
  - In tempo reale
  - Raccomandazioni cosa investigare/come mitigare/rimediare

Policy Based Management

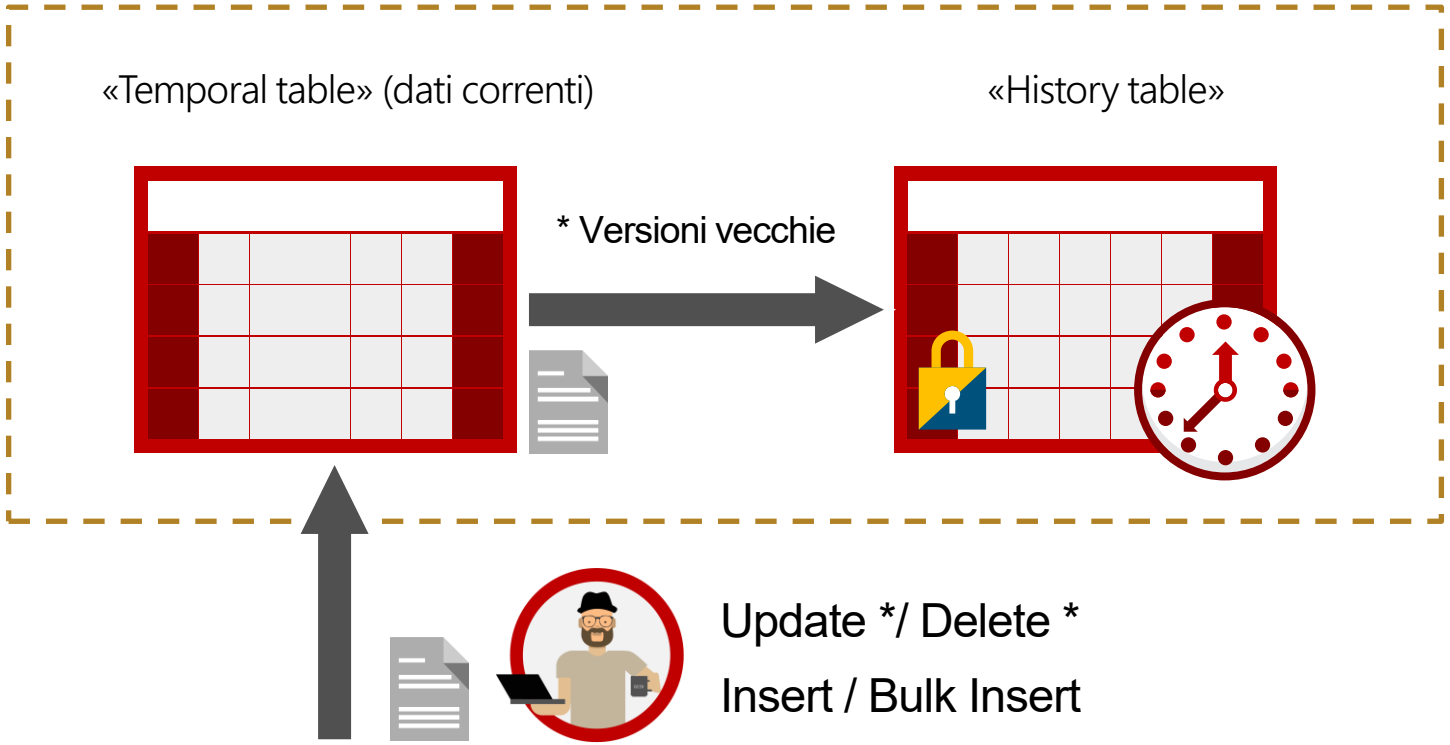
- Infrastruttura per
  - Definizione «policy»
  - Controllo conformità installazione con «policy»
- Serie di «policy» conformi a Best Practice
  - Categoria di policy per sicurezza!
- Enterprise Policy Management Framework
  - http://aka.ms/epmframework

Change Data Capture

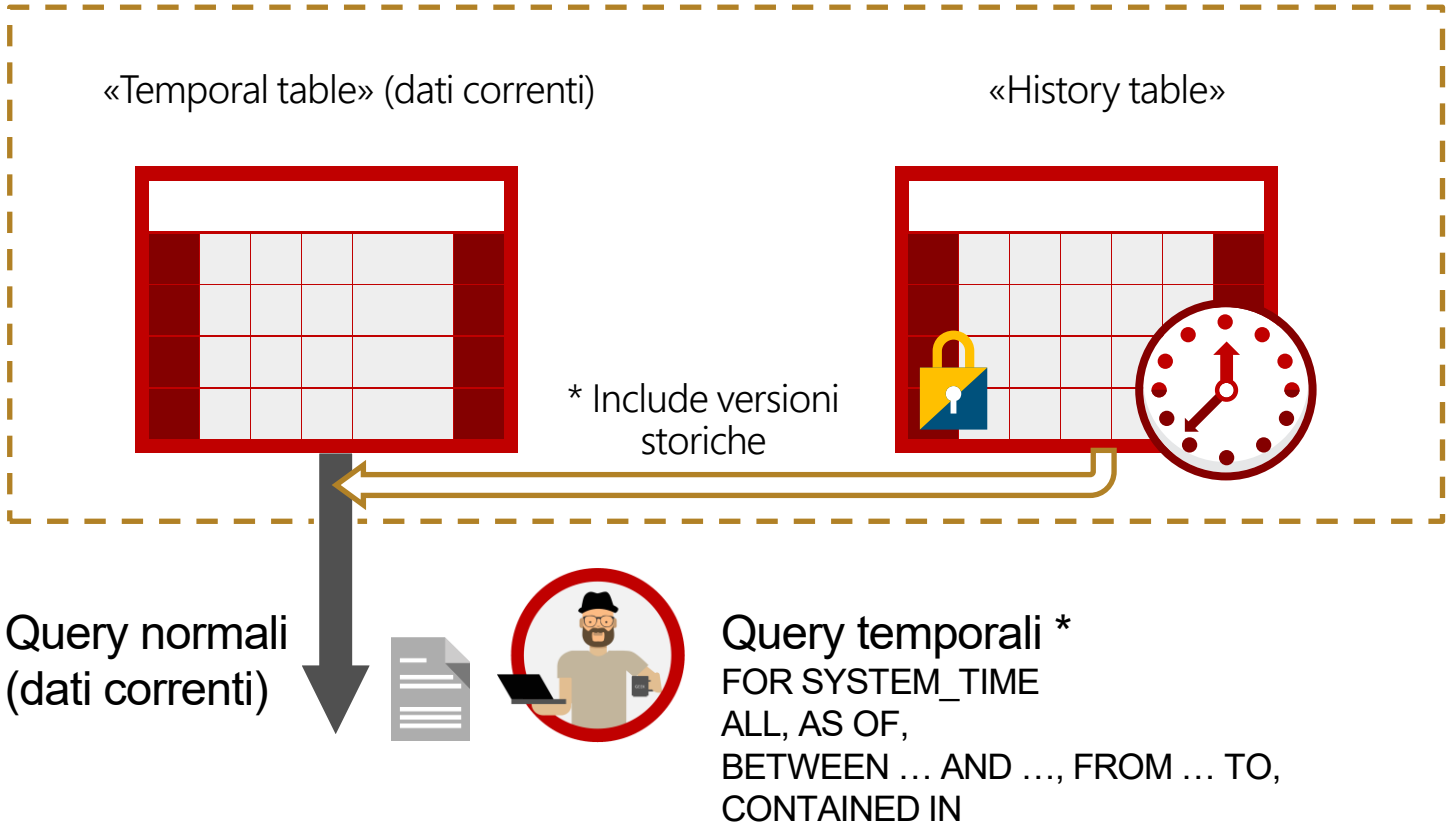
- Soluzione tradizionale Audit modifiche dati?
  - Trigger! Ma…
  - …complessità, prestazioni… ☹
- CDC cattura automaticamente modifiche
  - Pensato principalmente per caricare DWH
  - Genericamente va bene per tenere storico modifiche



Modifiche Database Temporali



Interrogazioni Database Temporali



Grazie

Domande?

https://github.com/ghotz

@glhotz

https://www.linkedin.com/in/ghotz